

NIST/FIPS Documents

- **FIPS 199: Standards for Security Categorization of Federal Information and Information Systems** – This document is proposed to provide the standardization of categories for federal information systems based on confidentiality, integrity, and availability. Impact of each of these metrics is rated with high, medium, and low severity; each level is defined with examples given including damage to assets, finances, or people.
- **FIPS 200: Minimum Security Requirements for Federal Information and Information Systems** – This document is a full framework document with regards to the standards, procedures, fundamentals, etc. of federal information systems. Topics range from communication and reporting, risk management, organization, information security and privacy.
- **FIPS 140-3: Security Requirements for Cryptographic Modules** – This document sets the standard for technological and procedural safeguards with cryptographic security systems within telecommunication systems. This is to keep information secure throughout services, software/firmware, life-cycles, tests, operating environments, etc.
- **800-18: Guide for Developing Security Plans for Federal Information Systems** - This document is to structure a plan for securing information systems. It goes over requirements, controls, and responsibilities for multiple roles.
- **800-30: Guide for Conducting Risk Assessments** - This document guides the standard for conducting risk assessments in government systems. This document goes over fundamental concepts and procedures for the preparation, conduction, communication, and maintenance of risk assessments.
- **800-34: Contingency Planning Guide for Federal Information Systems** - This document aims to define and help readers with the formation of contingency plans. When systems inevitably disrupt, it is important for an entity to be able to react accordingly and effectively to rectify the issue.
- **800-39: Managing Information Security Risk: Organization, Mission, and Information System View** - This document focuses on guidance for the managing, operations,

assets, individual use of federal information systems and their risk. This document also discusses the process of framing, assessing, responding and monitoring risk.

- **800-37 Rev. 2: Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy** - This document provides the guidelines on how to apply a risk management framework to the information systems of an organization. The process includes the preparation, categorization, selection, implementation, assessment, authorization, and monitoring of executing risk management framework tasks.
- **800-50: Building a Cybersecurity and Privacy Learning Program** - This document provides guidance on how to develop and implement a cybersecurity learning program. It goes over strategy, planning, analysis, design, development and assessment of the learning program.
- **800-53(A) Rev. 5: Assessing Security and Privacy Controls in Information Systems and Organizations** - This document talks about the methodologies behind assessing security and privacy controls. These methodologies include procedures such as: access controls, audits, assessments, supply chain, planning, risk assessments, identification, contingency, maintenance, and configuration.
- **800-53 Rev. 5: Security and Privacy Controls for Information Systems and Organizations** - This document is a catalog of security and privacy controls. These controls are meant to address risks ranging from natural disasters to cyber attacks and are meant to address requirements ranging from laws, business needs and other policies.
- **800-59: Guideline for Identifying an Information System as a National Security System** - This document identifies certain information systems as national security systems. This helps determine responsibility, provides a checklist, and disputes some resolutions. Some items in this checklist include intelligence activities, cryptologic activities, military controls, and weapon systems.
- **800-60 Vol. I: Guide for Mapping Types of Information and Information Systems to Security Categories** - This document develops standards on how federal agencies categorize information systems collected.

- **& II: Guide for Mapping Types of Information and Information Systems to Security Categories: Appendices** - This document provides the guidelines for recommendations to which information systems are considered in certain categories.
- **800-61: Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile** - This document provides response recommendations to cybersecurity risk incidents. This document organizes and rates each organization element on its severity to operations.
- **800-64 Rev. 2:** - This document has been withdrawn. The original purpose of this document was to help agencies build security into the IT development process. It goes over system development life cycles and considerations to supply chain, cross-organization solutions, technology advancement, data center development, and virtualization.
- **800-128: Guide for Security-Focused Configuration Management of Information Systems** - This document provides guidelines for organizations that focus on federal information security. Topics range from identifying/implementing configurations, controlling configuration changes, monitoring, planning, analysis, controls, and tools.
- **800-145: The NIST Definition of Cloud Computing** - This document sets the definition for what Cloud computing is. Cloud computing is defined as a model for on-demand network access to a shared computing resource with minimal management effort. This document also defines SaaS, PaaS, IaaS, and deployment models.
- **800-207: Zero Trust Architecture** - This document designs the practices behind zero trust in information security practices. By the document's standard, zero trust is meant to protect assets by assuming no trust granted implicitly based on location whether it be physical or network.